

On the Accuracy of GitHub's Dependency Graph

Nicolas Marcelo Rivas Rojas

¿Cuál es el problema que se está resolviendo?

El artículo investiga la precisión del gráfico de dependencias de GitHub, una característica utilizada para gestionar y visualizar dependencias en repositorios de software. Se busca determinar si la información que proporciona este gráfico es confiable para tareas como la seguridad del software y la generación de Software Bill of Materials (SBOM)

¿Cuál es la nueva idea que están proponiendo?

El estudio analiza la precisión del gráfico de dependencias de GitHub en proyectos de Java y Python, señalando posibles inexactitudes que afectarían su utilidad en seguridad y mantenimiento de software.

Los autores realizan tres análisis:

Backward Analysis: Compara las dependencias listadas en GitHub con los archivos reales del proyecto.

Forward Analysis: Verifica si los repositorios que, según GitHub, dependen de un proyecto realmente lo referencian.

Manifest/lock File Analysis: Contrasta las dependencias reportadas por GitHub con las especificadas en los archivos de configuración (pom.xml, requirements.txt).

El estudio detecta múltiples inexactitudes en el gráfico de GitHub, lo que puede afectar herramientas como Dependabot y estudios que han confiado en estos datos.

Puntos positivos

El estudio analiza una muestra significativa de proyectos en dos lenguajes y aplica un enfoque estructurado para evaluar la precisión del gráfico de dependencias, reforzando la validez de sus conclusiones.

La investigación tiene aplicaciones inmediatas, ya que herramientas de seguridad y mantenimiento dependen de estos gráficos. Detectar inexactitudes ayuda a mejorarlas.

Puntos negativos

Si bien Python y Java son lenguajes populares, se excluyeron otros que podrían ser igual o más, como, por ejemplo: Javascript

El análisis se centra en datos y métricas, pero no incluye entrevistas o encuestas con desarrolladores para entender cómo perciben la utilidad del gráfico de dependencias en su trabajo diario

Trabajo futuro

Investigar cómo GitHub maneja las dependencias en otros lenguajes populares como JavaScript/Node.js, Rust o Go. Esto permitiría evaluar si los problemas detectados son específicos de Java y Python o si afectan a todo el ecosistema

Realizar encuestas o entrevistas con desarrolladores que utilizan Dependabot u otras herramientas basadas en el gráfico de GitHub para entender cómo las inexactitudes afectan su flujo de trabajo y qué soluciones podrían ser útiles.

Calificación

(4.5) El paper está bien estructurado, aborda un problema relevante y utiliza un enfoque sólido. Sin embargo, la falta de validación con desarrolladores y la exclusión de otros lenguajes deja espacio para mejoras

Puntos de discusión

¿Qué impacto tienen los errores en la detección de dependencias en la seguridad de los proyectos?

¿Es suficiente confiar en herramientas automatizadas como GitHub Dependency Graph y Dependabot, o deberíamos combinarlas con validaciones manuales para evitar errores?